

Automated Compliance Assessment Report

Primebrick v3 — Security & Compliance Posture

88.2%

Overall Score

14 compliant · 2 partial · 0 not found · 1 non-compliant

1953 evidence items found across 5 repositories

1 violations detected

41 unpinned dependencies

Framework Scores

Framework	Controls	Compliant	Partial	Not Found	Non-Compliant	Score
ISO 27001	17	14	2	0	1	88.2%
NIS2	14	11	2	0	1	85.7%
GDPR	10	9	1	0	0	95%
CCPA	6	5	1	0	0	91.7%
OWASP	7	5	1	0	1	78.6%

Control Assessment Details

Role-Based Access Control

Fine-grained permission system with role mappings

ISO 27001: A.5.15, A.8.2, A.8.3 · NIS2: Art. 21(2)(b) · GDPR: Art. 5(1)(f), Art. 32 · CCPA: §1798.150(a)(1)

304 evidence items in backend, frontend, microservices

❗ backend/src/domain/entities/registry.ts:10 import { RoleMappingEntity } from "../../modules/auth/role_mapping_entity.js";

❗ backend/src/http/api-errors.ts:170 * Authentication ok, but the user lacks the required permissions.

❗ backend/src/http/api-errors.ts:171 * `extra.issues` SHOULD contain the missing permissions for the caller to inspect

COMPLIANT

[CRITICAL]

Multi-Factor Authentication

MFA enforced at the identity provider (TOTP, hardware keys, passkeys)

ISO 27001: A.8.5 · NIS2: Art. 21(2)(j) · GDPR: Art. 32(1)(b) · CCPA: §1798.150(a)(1)

3 evidence items in backend, frontend, sdk

❗ sdk/src/auth/types.ts:106 * Whether WebAuthn / passkey passwordless authentication is enabled.

❗ sdk/src/auth/types.ts:107 * When false, the BE WebAuthn endpoints return 503 and the FE hides the

❗ sdk/src/auth/types.ts:108 * passkey button. Parsed from the "true"/"false" string in the DB.

COMPLIANT

[CRITICAL]

Audit Trail / Logging

Immutable audit log for all CRUD operations

ISO 27001: A.8.15, A.8.16 · NIS2: Art. 21(2)(b) · GDPR: Art. 30, Art. 33 · CCPA: §1798.130(a)(5)(A)

115 evidence items in backend, dal

❗ backend/src/db/audit-port-adapter.ts:2 import { AuditLogEntity } from "@primebrick/dal-pg";

❗ backend/src/db/audit-port-adapter.ts:7 async writeAudit(params: AuditParams): Promise<void> {

❗ backend/src/db/audit-port-adapter.ts:16 await this.repo.add(AuditLogEntity, {

COMPLIANT

[HIGH]

Multi-Tenant Data Isolation

Organization-level data isolation at the DAL layer

ISO 27001: A.8.3 · NIS2: Art. 21(2)(d) · GDPR: Art. 5(1)(c), Art. 32 · CCPA: §1798.150(a)(1)

1 evidence items in backend, dal, sdk

PARTIALLY COMPLIANT

[CRITICAL]

🔗 sdk/src/auth/session-context.ts:90 * scope — meaning the caller forgot to wrap the code in `runAsSystem()` or

Soft-Delete & Recovery

COMPLIANT

Records are soft-deleted (deleted_at) and can be restored

[MEDIUM]

GDPR: Art. 17, Art. 15 · ISO 27001: A.8.10 · NIS2: Art. 21(2)(c)

136 evidence items in backend, dal

🔗 backend/src/db/entity-ts-to-pg.ts:83 sl === "deleted_at" ||

🔗 backend/src/db/entity-ts-to-pg.ts:114 sl === "deleted_at"

🔗 backend/src/db/repository/query-builder.ts:47 return Boolean(meta.columns["deleted_at"]);

Input Validation

COMPLIANT

Schema-based input validation (Zod, Joi, etc.)

[HIGH]

ISO 27001: A.8.28, A.8.25 · NIS2: Art. 21(2)(e) · GDPR: Art. 5(1)(c) · OWASP: A03:2021 — Injection

33 evidence items in backend, microservices, sdk, dal

🔗 backend/src/http/validation.ts:2 import { z } from "zod";

🔗 backend/src/http/validation.ts:25 const r = schema.safeParse(req.query);

🔗 backend/src/http/validation.ts:37 const r = schema.safeParse(req.body);

Encryption in Transit (TLS/HTTPS)

COMPLIANT

TLS/HTTPS enforced for all API traffic

[HIGH]

ISO 27001: A.8.24 · NIS2: Art. 21(2)(g) · GDPR: Art. 32(1)(a) · CCPA: §1798.150(a)(1)

25 evidence items in backend, frontend

🔗 backend/src/http/api-errors.ts:251 // https://www.postgresql.org/docs/current/errcodes-appendix.html

🔗 backend/src/modules/auth/services/auth-session.service.ts:17 * writes them as httpOnly cookies. This keeps `res` out of the service.

🔗 backend/src/modules/auth/services/auth-session.service.ts:402 * Writes the auth tokens as httpOnly cookies on the response. This is the ONLY

Rate Limiting

PARTIALLY COMPLIANT

API rate limiting to prevent abuse and DoS

[MEDIUM]

NIS2: Art. 21(2)(c) · ISO 27001: A.8.6 · OWASP: A04:2021 — Insecure Design

1 evidence items in backend, microservices

🔗 backend/src/openapi/openapi.ts:561 "429": { description: "Too many login attempts" },

JWT Authentication

COMPLIANT

Short-lived JWT access tokens with refresh token rotation

[HIGH]

ISO 27001: A.8.5 · NIS2: Art. 21(2)(j) · GDPR: Art. 32(1)(b) · OWASP: A07:2021 — Auth Failures

132 evidence items in backend, frontend, sdk, microservices

🔗 backend/src/modules/auth/auth.middleware.ts:6 * The SDK handles JWT verification (STANDALONE mode) or gateway header

🔗 backend/src/modules/auth/auth.middleware.ts:9 * The BE operates in STANDALONE mode — it receives a raw JWT, verifies it

🔗 backend/src/modules/auth/auth.middleware.ts:106 if (!authHeader && req.cookies?.access_token) {

OAuth 2.0 / OIDC Identity Provider

COMPLIANT

Delegated authentication via Casdoor/OIDC

[HIGH]

ISO 27001: A.8.5 · NIS2: Art. 21(2)(j) · GDPR: Art. 32(1)(b)

401 evidence items in backend, frontend, sdk

🔗 backend/src/index.ts:7 import CasdoorSDK from "casdoor-nodejs-sdk";

🔗 backend/src/index.ts:86 // Initialize Casdoor SDK

🔗 backend/src/index.ts:95 // Call the correct version endpoint from Casdoor docs with authentication

Parameterized Queries (SQL Injection Prevention)

COMPLIANT

All database queries use parameterized inputs

[CRITICAL]

ISO 27001: A.8.28 · OWASP: A03:2021 — Injection · NIS2: Art. 21(2)(e)

66 evidence items in backend, dal

🔗 backend/src/db/audit-query-helper.ts:57 * No raw SQL — fully typed via DAL-pg query DSL.

🔗 backend/src/db/build-database-snapshot.ts:23 const r = await pool.query<{ schema: string; table: string; col: string }>({

🔗 backend/src/db/build-database-snapshot.ts:69 const existsR = await pool.query<{ oid: string }>({

Secrets Management No hardcoded secrets; secrets loaded from environment ISO 27001: A.5.17 · NIS2: Art. 21(2)(g) · OWASP: A02:2021 — Cryptographic Failures 73 evidence items in backend, frontend, microservices, sdk, dal · 1 violations ❗ backend/src/db/dal-gateway.ts:8 const connectionString = process.env.DATABASE_URL; ❗ backend/src/db/pool.ts:1 import "dotenv/config"; ❗ backend/src/db/pool.ts:15 const url = process.env.DATABASE_URL; ❗ backend/src/modules/mcp/__tests__/token-verifier.test.ts:137 oidc: { client_id: "test-client", client_secret: "test-secret" },	NON COMPLIANT [CRITICAL]
CORS Configuration Proper CORS configuration to restrict cross-origin access ISO 27001: A.8.23 · OWASP: A05:2021 — Security Misconfiguration 6 evidence items in backend, microservices ❗ backend/src/index.ts:1 import cors from "cors"; ❗ backend/src/index.ts:32 app.use(cors({ origin: true })); ❗ backend/src/modules/index.ts:6 * (Express bootstrap, CORS, cookies, error handler) and makes the set of	COMPLIANT [MEDIUM]
Health Checks & Monitoring Service health endpoints and monitoring NIS2: Art. 21(2)(c) · ISO 27001: A.8.16 231 evidence items in backend, microservices, sdk ❗ backend/src/domain/entities/registry.ts:12 import { ServiceRegistryEntity } from "../modules/system/service_registry_ent ❗ backend/src/domain/entities/registry.ts:19 ServiceRegistryEntity, ❗ backend/src/http/api-errors.ts:206 * which would trigger a /health probe and show a misleading	COMPLIANT [LOW]
Service Registry & Discovery Microservices register via NATS for dynamic discovery NIS2: Art. 21(2)(d) · ISO 27001: A.5.23 278 evidence items in backend, microservices, sdk ❗ backend/src/domain/entities/registry.ts:12 import { ServiceRegistryEntity } from "../modules/system/service_registry_ent ❗ backend/src/domain/entities/registry.ts:19 ServiceRegistryEntity, ❗ backend/src/index.ts:24 import { ServiceRegistryRepo } from "../modules/proxy/service-registry-repo.js";	COMPLIANT [LOW]
Structured Error Handling Centralized error handling with proper HTTP status codes ISO 27001: A.8.25 · OWASP: A09:2021 — Security Logging 94 evidence items in backend, microservices, sdk ❗ backend/src/http/api-errors.ts:32 export class ApiError extends Error { ❗ backend/src/http/api-errors.ts:55 this.name = "ApiError"; ❗ backend/src/http/api-errors.ts:83 export class NotFoundError extends ApiError {	COMPLIANT [LOW]
Data Minimization (Field-Level Access) API responses only include fields the user is authorized to see GDPR: Art. 5(1)(c) · ISO 27001: A.8.3 · CCPA: §1798.100(d) 54 evidence items in backend, dal ❗ backend/src/db/audit-query-helper.ts:2 import { AuditLogEntity, Project, Filter, Sort, field, buildAuditTrailJoins } fr ❗ backend/src/db/audit-query-helper.ts:66 filters: [Filter.fieldValue(field(AuditLogEntity, "entity_uuid"), "=", opts.ent ❗ backend/src/db/audit-query-helper.ts:80 filters: [Filter.fieldValue(field(AuditLogEntity, "entity_uuid"), "=", opts.ent	COMPLIANT [MEDIUM]
Dependency Issues frontend: 41 unpinned dependencies	

Disclaimer

This report is generated by an automated code pattern scanner. It detects the presence of security controls in the source code but does not constitute a formal compliance certification. Organizations should engage qualified auditors for official certification. The scanner maps code evidence to framework controls based on pattern matching — false positives and false negatives are possible.